

BÀI 4

Các nguy cơ bảo mật trên hệ thống

Nội dung

- Mục đích
- Các bước thực hiện
- Crack mật khẩu
- Leo thang đặc quyền
- Chạy ứng dụng
 - Keylogger
 - Spyware
- Ẩn file
 - Rootkits
 - Luồng dữ liệu NTFS
 - Steganography
- Xoá dấu vết
- Kiểm thử
- Bài tập

Mục đích

What you have at this stage:

Footprinting Module

1. IP Range
2. Namespace
3. Employee web usage

Scanning Module

1. Target assessment
2. Identification of services
3. Identification of systems

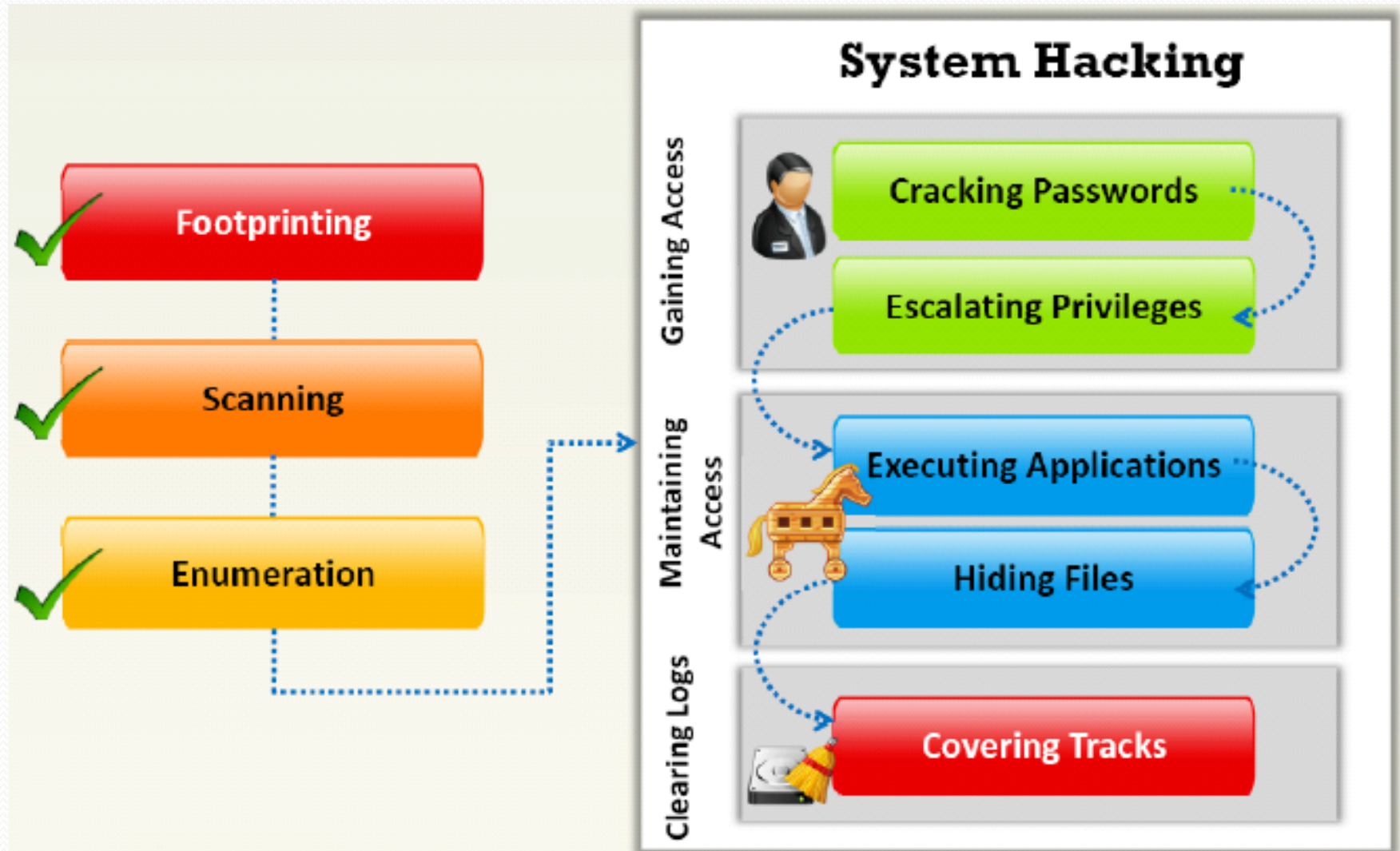
Enumeration Module

1. Intrusive probing
2. User lists
3. Security flaws

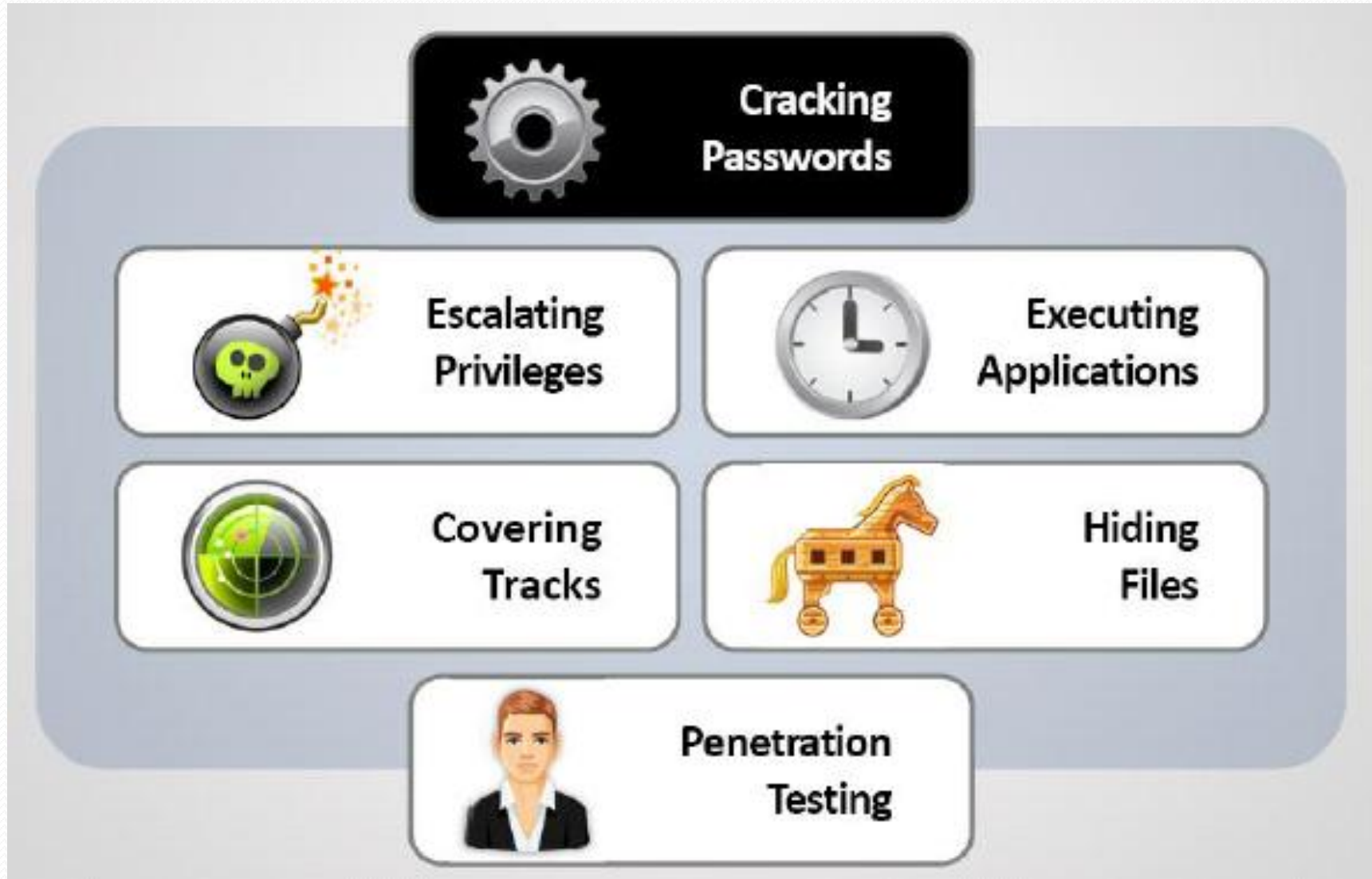
Mục đích

Hacking-Stage		Goal		Technique/Exploit Used
 G aining Access	➤	To bypass access controls to gain access to the system	➤	Password cracking, social engineering
 E scalating Privileges	➤	To acquire the rights of another user or an admin	➤	Exploiting known system vulnerabilities
 E xecuting Applications	➤	To create and maintain remote access to the system	➤	Trojans, spywares, backdoors, keyloggers
 H iding Files	➤	To hide attackers malicious activities and data theft	➤	Rootkits, steganography
 C overing Tracks	➤	To hide the evidence of compromise	➤	Clearing logs

Mục đích



Các bước thực hiện



Crack mật khẩu



Password cracking techniques are used to recover passwords from computer systems



Attacker



Attackers use password cracking techniques to gain unauthorized access to the vulnerable system



Vulnerable System



Most of the password cracking techniques are successful due to weak or easily guessable passwords

Crack mật khẩu



Passwords that contain letters, special characters, and numbers **ap1@52**



Passwords that contain only numbers **23698217**



Passwords that contain only special characters **&*#@!(%)**



Passwords that contain letters and numbers **meet123**



Passwords that contain only letters **POTHMYDE**



Passwords that contain only letters and special characters **bob@&ba**



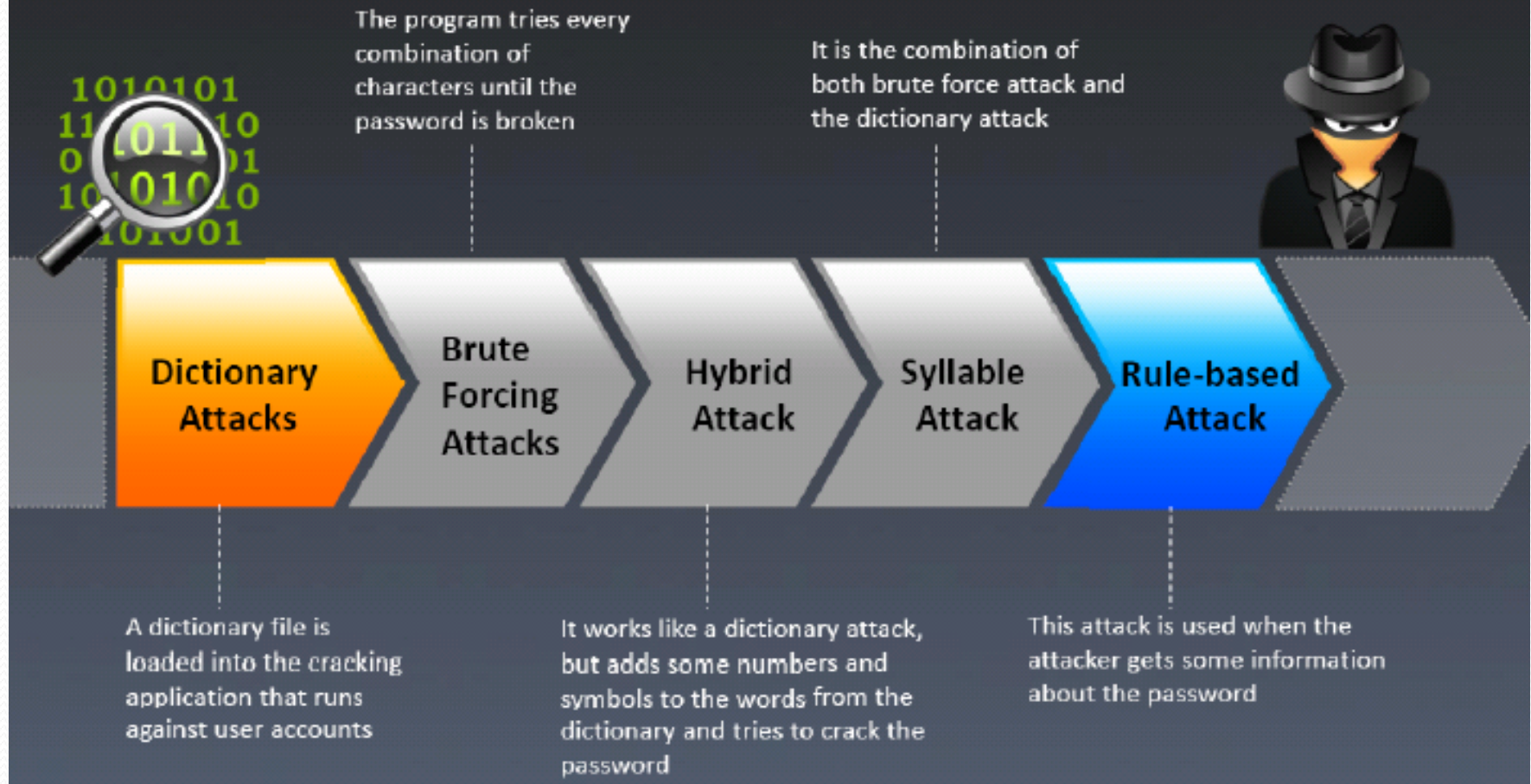
Passwords that contain only special characters and numbers **123@\$45**



**Password
Complexity**

Crack mật khẩu

Password Cracking Techniques



Crack mật khẩu

Types of Password Attacks



Crack mật khẩu

Passive Online Attacks: **Wire Sniffing**

Attackers run packet sniffer tools on the LAN to access and record the raw network traffic



Victim



Attacker



Victim

The captured data may include passwords sent to remote systems during Telnet, FTP, rlogin sessions, and electronic mail sent and received

Hard to Perpetrate

How effective is the attack?

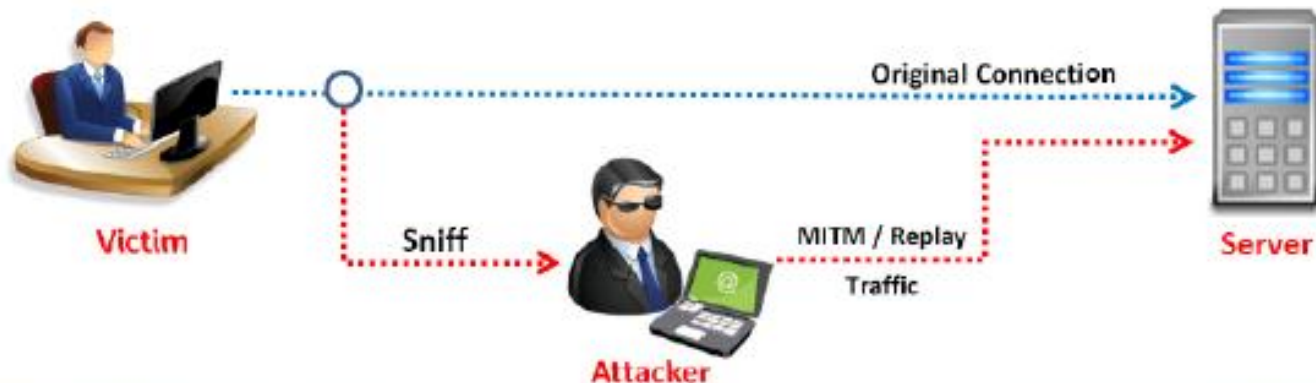
Computationally Complex

Attacker must sniff the network

Tools Available

Crack mật khẩu

Passive Online Attack: **Man-in-the-Middle** and **Replay Attack**



- In a MITM attack, the attacker acquires **access** to the communication channels between victim and server to extract the information
- In a replay attack, packets and authentication tokens are captured using a **sniffer**. After the relevant info is extracted, the tokens are placed back on the network to gain access

Considerations:

1. Relatively hard to perpetrate
2. Must be trusted by one or both sides
3. Can sometimes be broken by invalidating traffic

Crack mật khẩu

Active Online Attack: Password Guessing

The attacker takes a set of dictionary words and names, and tries all the possible combinations to crack the password

Considerations:

- Time consuming
- Requires huge amounts of network bandwidth
- Easily detected



Crack mật khẩu

Active Online Attack: Trojan/Spyware/Keylogger

A Keylogger is a program that runs in the background and allows remote attackers to **record every keystroke**

Keylogger



Spyware

Spyware is a type of malware that allows attackers to **secretly** gather information about a person or organization

Trojan

With the help of a Trojan, an attacker gets access to the **stored passwords** in the attacked computer and is able to read personal documents, delete files, and display pictures

Crack mật khẩu

Active Online Attack: Hash Injection Attack

- A hash injection attack allows an attacker to **inject a compromised hash** into a local session and use the hash to validate to network resources
- The attacker finds and extracts a logged on **domain admin account hash**
- The attacker uses the extracted hash to log on to the **domain controller**



Crack mật khẩu

Rainbow Attacks: Pre-Computed Hash

Rainbow Table

Convert huge word lists like dictionary files and brute force lists into password hashes using techniques such as rainbow tables

Computed Hashes

Compute the hash for a list of possible passwords and compare it with the precomputed hash table. If a match is found then the password is cracked

Compare the Hashes

It is easy to recover passwords by comparing captured password hashes to the precomputed tables

Precomputed Hashes

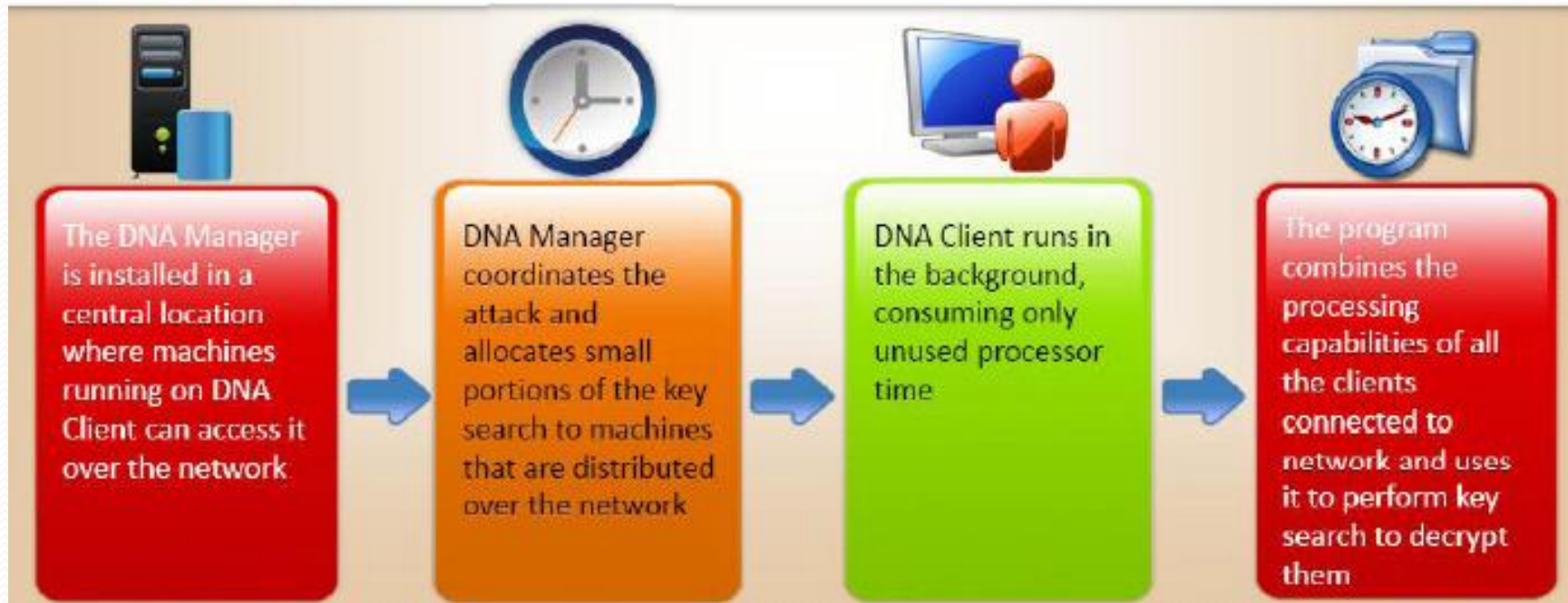
lqazwed	->	4259cc34599c530b28a6a8f225d668590
hh021da	->	c744b1716cbf8d4dd0ff4ce31a177151
9da8dasf	->	3cd696a8571a843cda453a229d741843
sodifo8sf	->	7ad7d6fa6bb4fd28ab98b3dd33261e8f



Crack mật khẩu

Distributed Network Attack

1. A Distributed Network Attack (DNA) technique is used for recovering password-protected files using the unused processing power of **machines across the network** to decrypt passwords
2. In this attack, a **DNA manager** is installed in a central location where machines running **DNA clients** can access it over the network



Crack mật khẩu

Non-Electronic Attacks



Crack mật khẩu

Default Passwords

A default password is a password supplied by the manufacturer with new equipment that is password protected



Online tools that can be used to search default passwords:



1. <http://www.phenoelit-us.org>
2. <http://www.defaultpassword.com>
3. <http://cirt.net>
4. <http://default-password.info>
5. <http://www.defaultpassword.us>
6. <http://www.passwordsdatabase.com>

Vendor	Model	Version	Access Type	Username	Password
3COM	CoreBuilder	7000/6000/3500/2500	Telnet	Debug	Synnet
3COM	CoreBuilder	7000/6000/3500/2500	Telnet	Tech	Tech
3COM	HiPerARC	v4.1.x	Telnet	Adm	(none)
3COM	LANplex	2500	Telnet	Debug	Synnet
3COM	LANplex	2500	Telnet	Tech	Tech
3COM	LinkSwitch	2000/2700	Telnet	Tech	Tech
Huawei	E960			Admin	Admin
3COM	NetBuilder		SNMP		ILMI
3COM	Netbuilder		Multi	Admin	(none)
3COM	Office Connect ISDN Routers	5x0	Telnet	n/a	PASSWORD
3COM	SuperStack II Switch	2200	Telnet	debug	Synnet
3COM	SuperStack II Switch	2700	Telnet	tech	Tech
3COM	OfficeConnect 812 ADSL		Multi	adminltd	adminltd

<http://www.phenoelit-us.org>

Crack mật khẩu

Manual Password Cracking (Guessing)



Frequency of attacks is **less**

Find a valid user

Create a list of possible passwords

Rank passwords from high probability to low

Key in each password, until correct password is discovered

The failure rate is **high**



Crack mật khẩu

Stealing Passwords Using **USB Drive**



- 

1 You will need a password hacking tool
- 

2 Copy the downloaded files to USB drive
- 

3 Create autorun.inf in USB drive
[autorun]
en=launch.bat
- 

4 Contents of launch.bat
start papv.exe/atext
papv.txt
- 

5 Insert the USB drive and the autorun window will pop-up (if enabled)
- 

6 Password2 is executed in the background and passwords will be stored in the .TXT files in the USB drive

Crack mật khẩu

How Hash Passwords are Stored in Windows SAM?



Martin/magician



Password hash using LM/NTLM

Martin:1008:624AAC413795CDC1
4E835F1CD90F4C76:6F585FF8FF6
280B59CCE252FDB500EB8:::

SAM File is located at `c:\windows\system32\config\SAM`

```
Administrator:500:598DDCE2660D3193AAD3B435B51404EE:2D20D252A479F485CDF5E171D93985BF:::  
Guest:501:NO PASSWORD*****:NO PASSWORD*****:::  
HelpAssistant:1000:B991A1DA16C539FE4158440889BE1FFA:2E83DB1AD7FD1DC981F36412863604E9:::  
SUPPORT_388945a0:1002:NO PASSWORD*****:F5C1D381495948F434C42AEE04DE990C:::  
Hackers:1003:37035B1C4AE2B0C5B75E0C8D76954A50:7773C08920232397CAE081704964B786:::  
Admin:1004:NO PASSWORD*****:NO PASSWORD*****:::  
Martin:1005:624AAC413795CDC1AAD3B435B51404EE:C5A237B7E9D8E708D8436B6148A25FA1:::  
John:1006:624AAC413795CDC1FF17365FAF1FFE89:3B1B47E42E0463276E3DED6CEF349F93:::  
Jason:1007:624AAC413795CDC14E835F1CD90F4C76:6F585FF8FF6280B59CCE252FDB500EB8:::  
Smith:1008:624AAC413795CDC14E835F1CD90F4C76:6F585FF8FF6280B59CCE252FDB500EB8:::
```

Username User ID

LM Hash

NTLM Hash

"LM hash has been disabled in Windows Vista and Windows 7, LM will be blank in those systems."

Crack mật khẩu

L0phtCrack

The screenshot displays the L0phtCrack 6 application window. The main menu bar includes 'Menu', 'View', and 'Help'. Below the menu is a toolbar with icons for 'Run Wizard', 'Import Hashes', 'Import From Sniffer', 'Begin', 'Pause', 'Stop', 'Session Options', 'Schedule Audit', 'Schedule Tasks', 'Cracked Accounts', 'Weak Passwords', 'Expired Accounts', 'Disable Accounts', and 'Force Password Change'.

The central pane shows a table of audit results with columns: Domain, User Name, LM Password, c8, Password, and Password Age (days). The table lists several users, including Admin, Administrator, Guest, HelpAssistant, and SUPPORT_3809H5a0.

On the right side, there are three status panels: 'DICTIONARY/HYBRID' showing words total (29155) and words done (29155), 'PRECOMPUTED' showing hash tables (0 of 0) and hashes found (0 of 0), and 'BRUTE FORCE' showing time elapsed (0d 0h 0m 0s) and time left (3 done).

At the bottom, a 'Messages' pane shows a log of events: '07/28/2010 18:02:16 Audit started.', '07/28/2010 18:02:16 Entered LM Dictionary Audit', '07/28/2010 18:02:16 Exited LM Dictionary Audit', and '07/28/2010 18:02:16 Auditing session completed.' A progress bar at the bottom indicates 'Audit completed'.

<http://www.l0phtcrack.com>

Crack mật khẩu

Ophcrack

ophcrack

Load Delete Save Tables Crack Help Exit About

Progress Statistics Preferences

User	LM Hash	NT Hash	LM Pwd 1	LM Pwd 2	NT Pwd
Admin		31d6cfe0d16ae931b7...			empty
Administrator	598DDCE2660D3193A...	2D20D252A479F485...	empty	empty	empty
Guest		31d6cfe0d16ae931b7...			empty
Hackers	3703581C4AE2B0C5B...	7773C08920232397C...	23		
HelpAssistant	B991A1DA16C539FE4...	2E83DB1AD7FD1DC9...	45		
Jason	624AAC413795CDC1...	6F585FF8FF6280B59...	4		
John	624AAC413795CDC1...	3B1B47E42E0463276...	empty		
Martin	624AAC413795CDC1...	C5A237B7E9D8E708...	45		
Smith	624AAC413795CDC1...	6F585FF8FF6280B59...			
SUPPORT_388945a0		F5C1D381495948F43...			

Table	Directory	Status	Progress
-------	-----------	--------	----------

Preload: done Brute force: done Pwd found: 2/10 Time elapsed: 0h 0m 43s

Crack mật khẩu

Cain & Abel

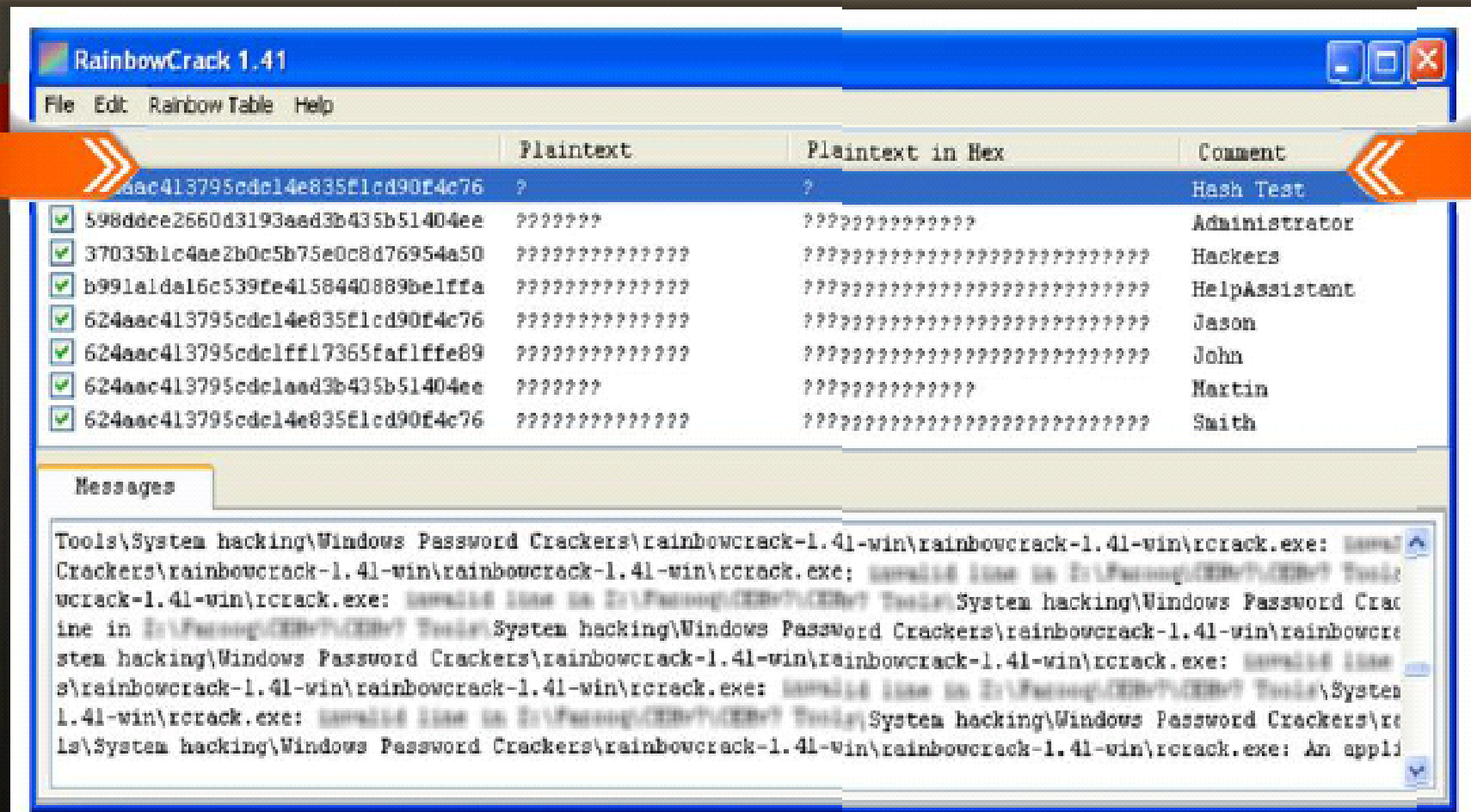
The screenshot shows the Cain & Abel software interface with the 'Cracker' tab selected. The main window displays a table of captured hashes and their corresponding user names. The table has columns for User Name, LM Password, NT Password, LM Hash, and NT Hash. The 'Cracker' tab is highlighted in the sidebar, and the 'Cracker' button is also highlighted in the toolbar. The interface is in Vietnamese, with the title bar and menu items in that language.

User Name	LM Password	< 0	NT Password	LM Hash	NT Hash
Admin	12345678	*		AAD3B435B514...	06587D8A1C6D...
Administrator	12345678	*		AAD3B435B514...	06587D8A1C6D...
Farooq	12345678	*		AAD3B435B514...	E34E8F38D8E0...
Guest	12345678	*		AAD3B435B514...	31D6CFE0D16A...
helpdesk@net	12345678	*		B47D3C0696F9...	D32D05B92E9C...
Guest	12345678	*		AAD3B435B514...	31D6CFE0D16A...
Administrator	12345678	*		AAD3B435B514...	5AC58C3D038...
Admin_Jackery_3	12345678	*		AAD3B435B514...	06587D8A1C6D...
Admin_Jackery_3	12345678	*		000000000000...	31D6CFE0D16A...
Administrator_Jackery_3	12345678	*		AAD3B435B514...	06587D8A1C6D...
Administrator_Jackery_3	12345678	*		000000000000...	31D6CFE0D16A...

URL: <http://www.oxid.it>

Crack mật khẩu

RainbowCrack



Crack mật khẩu

Password Cracking Tools



John the Ripper
<http://www.openwall.com>



Proactive System Password Recovery
<http://www.elcomsoft.com>



KerbCrack
<http://ntsecurity.nu>



Password Unlocker Bundle
<http://www.passwordunlocker.com>



Recover Keys
<http://recover-keys.com>



Windows Password Reset Professional
<http://www.resetwindowspassword.com>



Windows Password Cracker
<http://www.windows-password-cracker.com>



Windows Password Reset Standard
<http://www.resetwindowspassword.com>

Crack mật khẩu

How to Defend against Password Cracking?



Make passwords hard to guess by using 8-12 alphanumeric characters in combination of uppercase and lowercase letters, numbers, and symbols



Do not use the same password during password change



Set the password change policy to 30 days



Monitor the server's logs for brute force attacks on the users accounts



Avoid storing passwords in an unsecured location



Do not use passwords that can be found in a dictionary



Never use passwords such as date of birth, spouse, or child's or pet's name



Enable **SYSKEY** with strong password to encrypt and protect the SAM database

Leo thang đặc quyền



Leo thang đặc quyền

Privilege Escalation

An attacker can gain access to the network using a **non-admin user account**, and the next step would be to gain administrative privileges



Leo thang đặc quyền

StickyKeys

AdminUser

DomainUser



- ➔ StickyKeys is an accessibility feature in Windows OS to aid users who have physical disabilities. **Press shift key 5 times** at the logon screen and the StickyKey dialog shows up
- ➔ The program that launches the StickyKeys is located at **c:\windows\system32\sethc.exe**
- ➔ If we replace the sethc.exe which is responsible for the sticky key dialog, with **cmd.exe**, and then call **sethc.exe** by pressing shift key 5 times at logon screen, we will get a command prompt with administrator privileges

Leo thang đặc quyền

StickyKeys

AdminUser

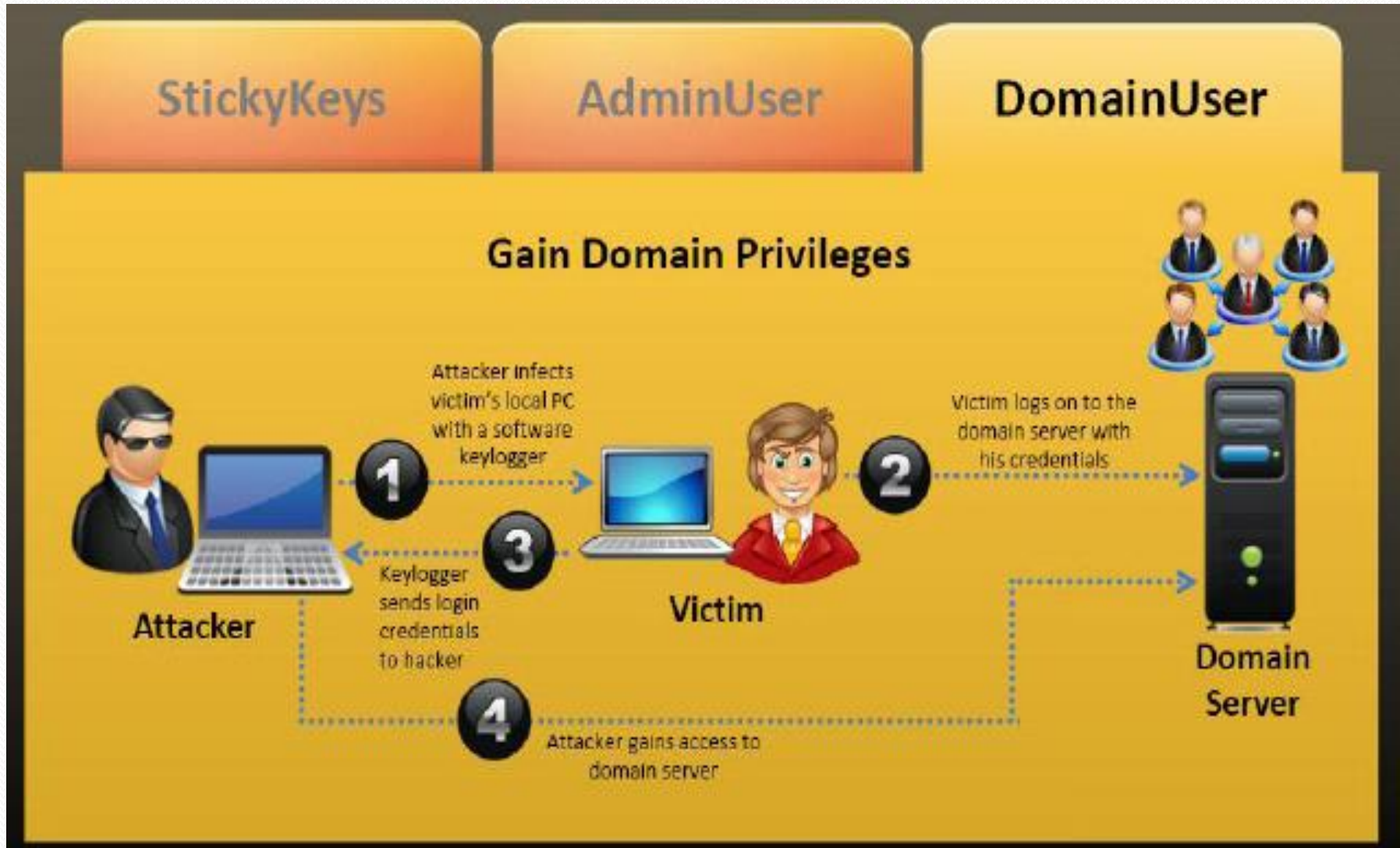
DomainUser

Create a hidden admin account



- ➔ Launch command prompt and type "**NET USER Juggyboy PASSWORD**" where "PASSWORD" can be any password you like and press enter
- ➔ Go to **registry** editor and navigate to the key
[HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\SpecialAccounts\UserList]
- ➔ Create a new **DWORD value**, write its name as the "Juggyboy," and close the registry editor
- ➔ Juggyboy will be a hidden user with Administrative privileges

Leo thang đặc quyền



Leo thang đặc quyền

Privilege Escalation Tools



Stellar Phoenix Password Recovery

<http://www.recoveranypassword.com>



Passware Password Recovery Kit

<http://www.lostpassword.com>



Password Unlocker Bundle

<http://www.passwordunlocker.com>



Offline NT Password & Registry Editor

<http://pogostick.net>



Windows Password Reset Kit

<http://www.reset-windows-password.net>



Windows Password Recovery Tool

<http://www.windowpasswordsrecovery.com>



ElcomSoft System Recovery

<http://www.elcomsoft.com>

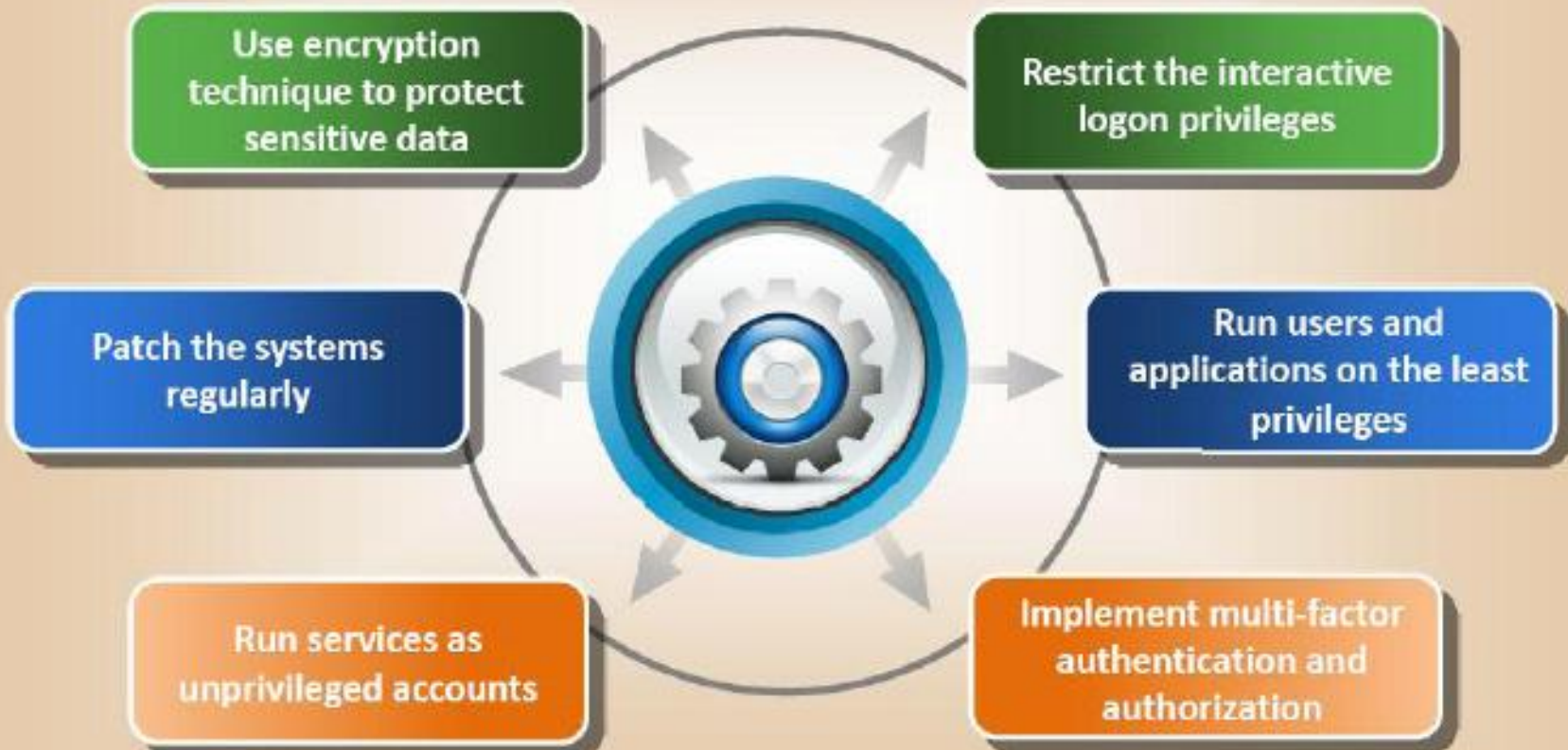


Trinity Rescue Kit

<http://trinityhome.org>

Leo thang đặc quyền

How to Defend against Privilege Escalation?



Chạy ứng dụng



**Cracking
Passwords**



**Escalating
Privileges**



**Executing
Applications**



**Covering
Tracks**



**Hiding
Files**



**Penetration
Testing**

Chạy ứng dụng

Executing Applications

Attackers execute malicious applications in this stage. This is called **"owning"** the system



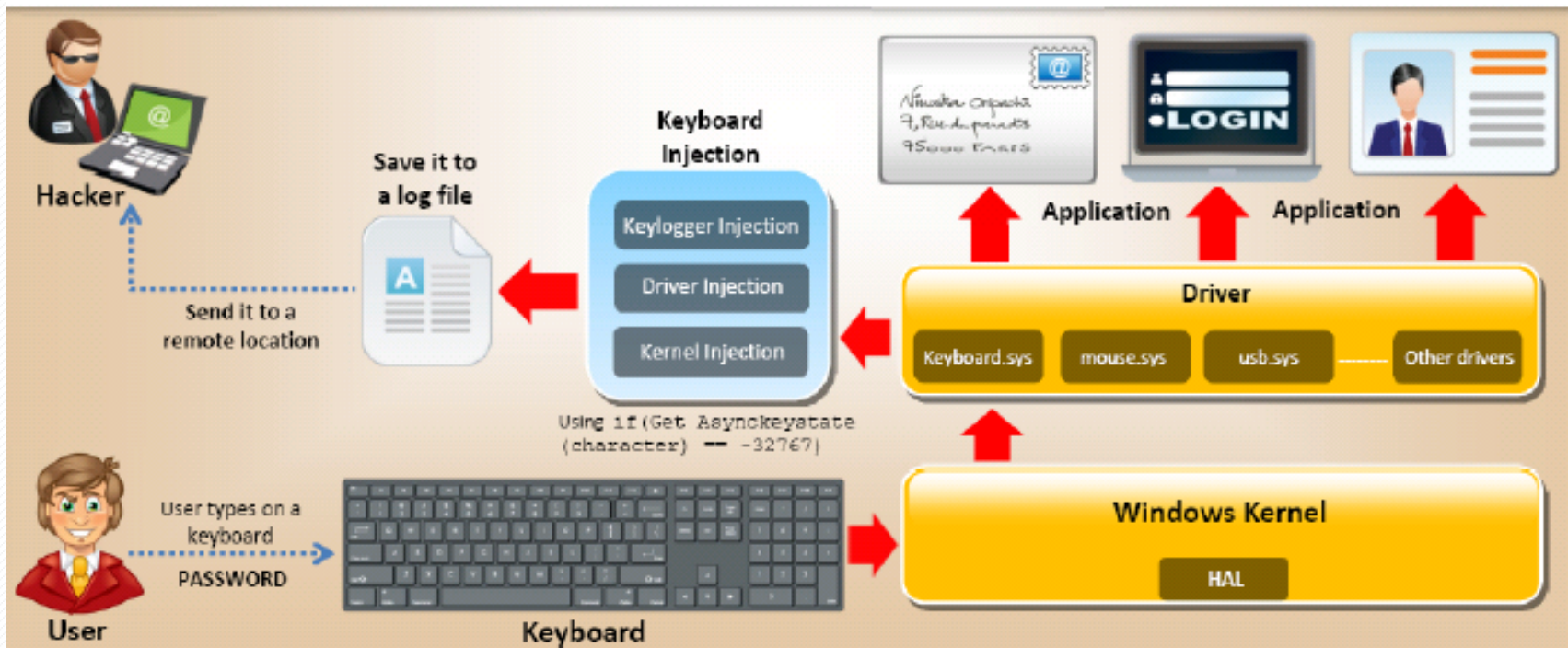
Chạy ứng dụng



Keylogger

Keylogger

- Keystroke loggers are programs or hardware devices that **monitor each keystroke** as user types on a keyboard; logs on to a file or transmits them to a remote location
- Keyloggers are placed between the **keyboard hardware** and the **operating system**
- Legitimate applications for keyloggers include in office and industrial settings to monitor employees' computer activities and in home environments where parents can monitor and spy on children's activity



Keylogger



PS/2 Keylogger



USB Keylogger



Wi-Fi Keylogger



Keylogger embedded
inside the keyboard



Bluetooth Keylogger



Hardware Keylogger

Keylogger

Keylogger: Advanced Keylogger



Keylogger

Keyloggers



iMonitorPC Business Plus

<http://www.imonitorpc.com>



XPCSpy Pro

<http://www.x-pcsoft.com>



PC Activity Monitor Standard

<http://www.pcacme.com>



Handy Keylogger

<http://www.handy-keylogger.com>



KeyProwler Pro

<http://www.keyprowler.com>



KeyProwler

<http://www.keyprowler.com>



PC Activity Monitor Lite

<http://www.pcacme.com>



Stealth Keylogger

<http://www.omplusnet.com>

Keylogger

How to Defend against Keyloggers?



Install **antivirus software** and keep the signatures up to date

Install a **Host-based IDS** which can monitor your system and disable the installation of keyloggers

Install good professional **firewall software** and **anti-keylogging software**



Keep your **hardware systems secure** in a locked environment and frequently check the keyboard cables for the attached connectors

Choose **new passwords** for different online accounts and change them frequently

Use software that frequently **scans** and **monitors** the changes in the system or network



Use **pop-up blocker** and avoid opening junk emails

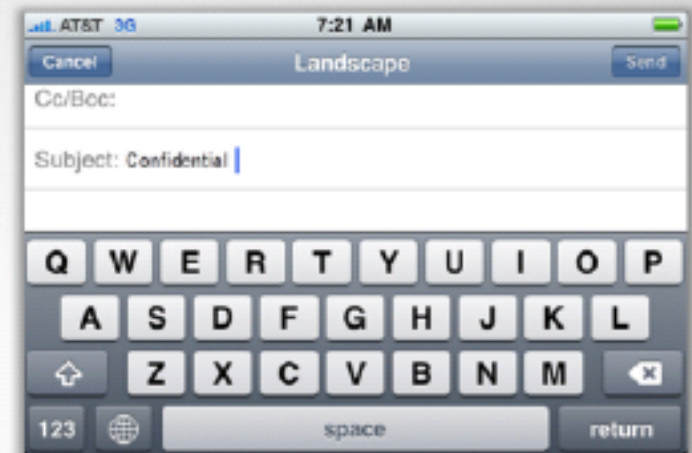
Scan the files before installing them on to the computer and use registry editor or process explorer to check for the keystroke loggers



Keylogger

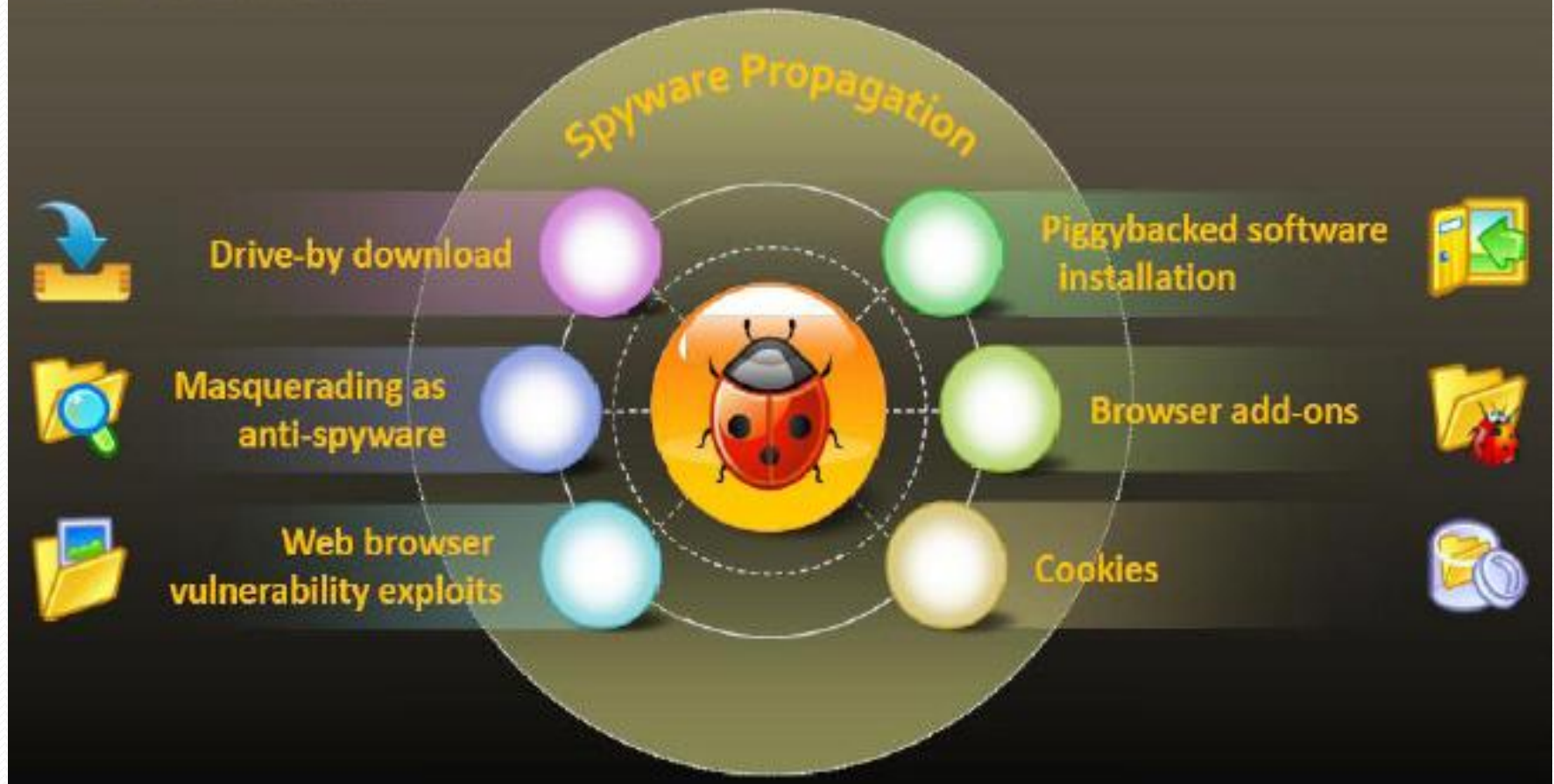
Anti-Keylogger

- Anti keyloggers detect and disable software keyloggers
- Some of the anti-keyloggers work by matching **signatures of keylogger code** with a signature database while others protect keyboard drivers and kernels from manipulation by keyloggers
- Using a **virtual keyboard** or touch screen makes it difficult for malicious spyware and Trojan programs to capture keystrokes



Spyware

Spyware is a program that **records user's interaction** with the computer and Internet without the a user's knowledge. Spyware is stealthy, hiding its process, files, and other objects in order to avoid removal.



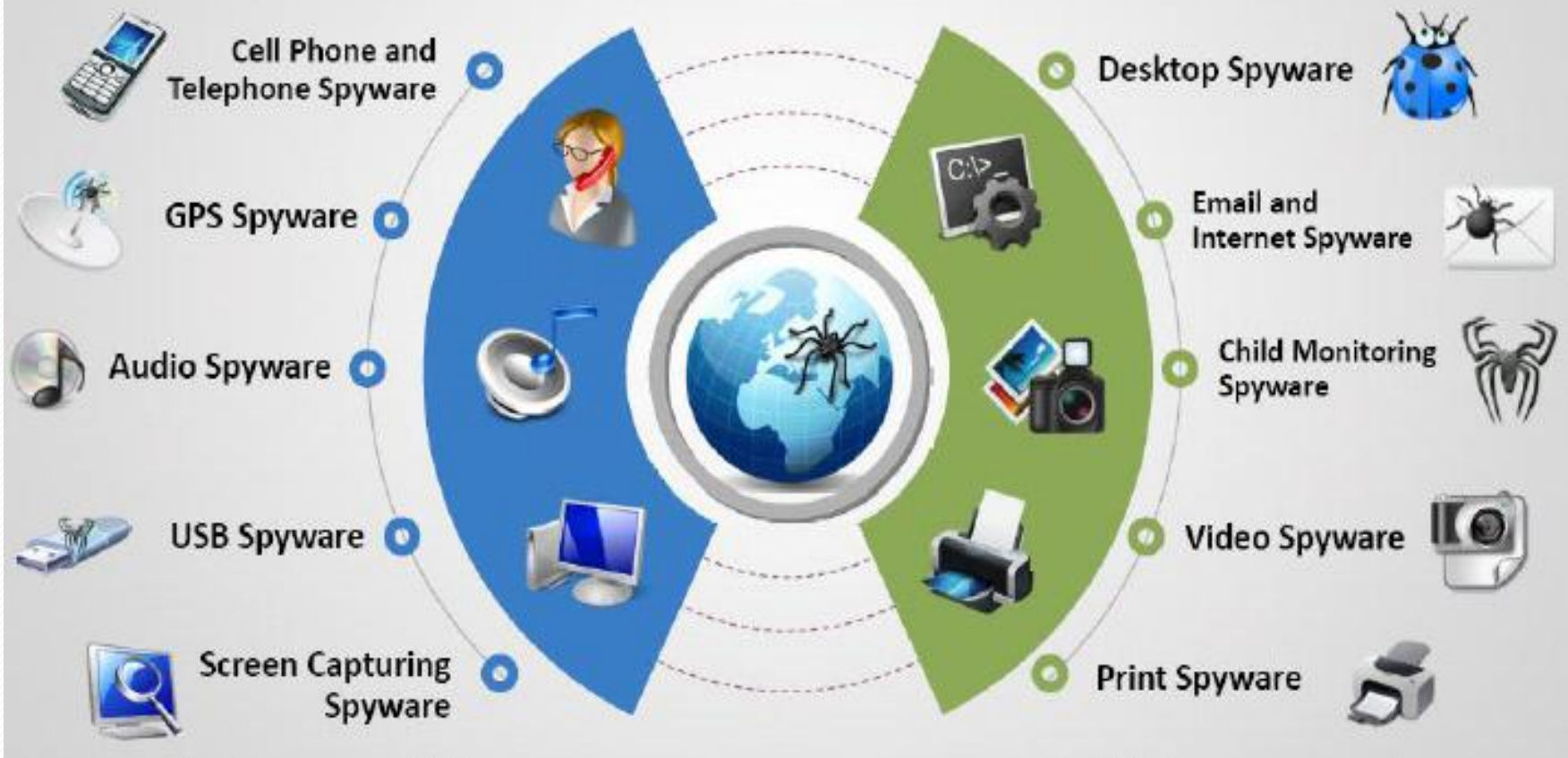
Spyware

What Does the **Spyware** Do?



Spyware

Types of Spywares



Spyware

How to Defend against Spyware?



Spyware

Anti-Spywares



CounterSpy

<http://www.sunbeltsoftware.com>



**Norton Internet Security
2011**

<http://www.symantec.com>



SpyHunter

<http://www.enigmaoftware.com>



Spyware Terminator

<http://www.spywareterminator.com>



**Kaspersky Internet Security
2011**

<http://www.kaspersky.com>



Ad-Aware

<http://www.lavasoft.com>



Spy Sweeper

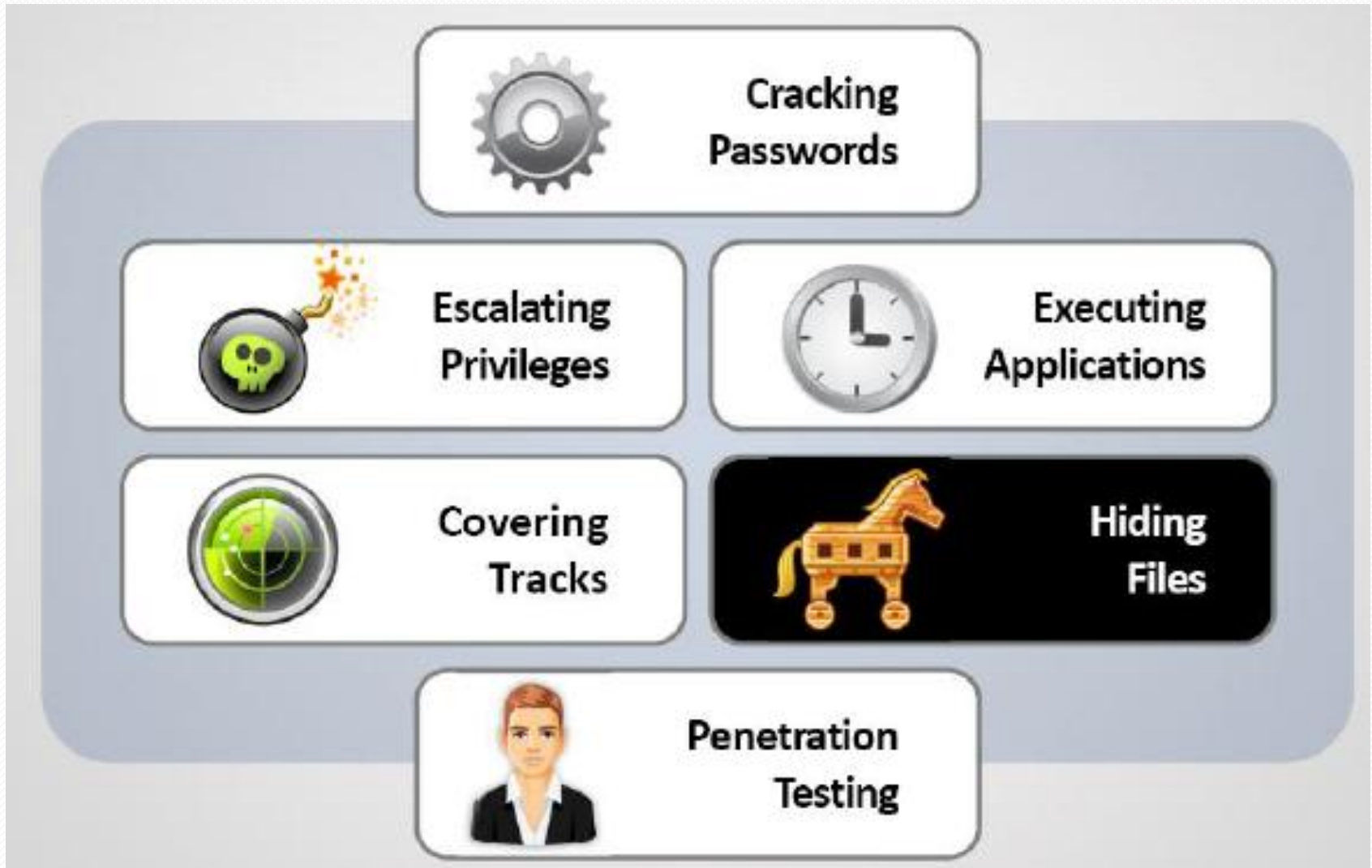
<http://www.webroot.com>



MacScan (for MAC OS X)

<http://macscan.securemac.com>

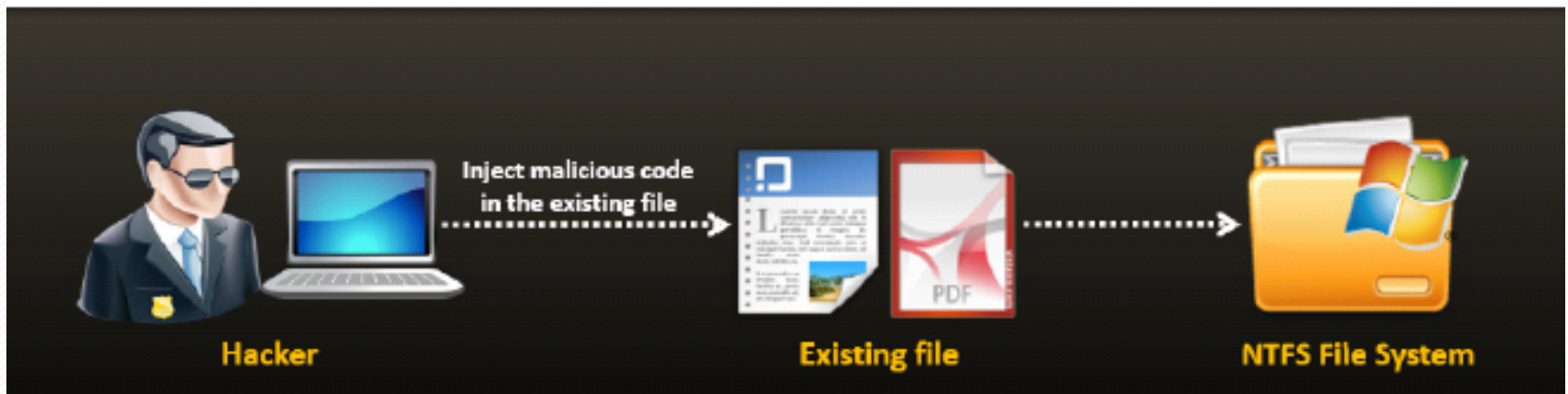
An file



Luồng dữ liệu NTFS

NTFS Data Stream

- NTFS Alternate Data Stream (ADS) is a **Windows hidden stream** which contains metadata for the file such as attributes, word count, author name, and access and modification time of the files
- ADS is the ability to **fork data into existing files** without changing or altering their functionality, size, or display to file browsing utilities
- ADS allows an attacker to **inject malicious code** on a breached system and executes them without being detected by the user



Luồng dữ liệu NTFS

How to Create NTFS Streams?

Notepad is stream compliant application

- 1 Launch `C:\>notepad myfile.txt:lion.txt`
Click 'Yes' to create the new file and type 10 lines of data
Save the file



- 2 Launch `C:\>notepad myfile.txt:tiger.txt`
Click 'Yes' to create the new file and type other 20 lines of text
Save the file



- 3 View the file size of `myfile.txt`
(It should be zero)



- 4 To modify the stream data, open document
'`myfile.txt:tiger.txt`' in notepad



Luồng dữ liệu NTFS

NTFS Stream Manipulation



Trojan.exe (size: 2 MB)

Move the contents of
Trojan.exe to Readme.txt
Location c:\ Location c:\



Readme.txt (size: 0)

To **move** the contents of Trojan.exe to Readme.txt (stream):

```
C:\> type c:\Trojan.exe > c:\Readme.txt:Trojan.exe
```

To **execute** the Trojan.exe inside the Readme.txt (stream):

```
C:\> start c:\Readme.txt:Trojan.exe
```

To **extract** the Trojan.exe from the Readme.txt (stream):

```
C:\> cat c:\Readme.txt:Trojan.exe > Trojan.exe
```

Note: Cat is a Windows 2003 Resource Kit Utility

Luồng dữ liệu NTFS

How to Defend against NTFS Streams?

Deleting a stream file involves copying the **front file** to a **FAT partition** and then copying it back to NTFS



Streams are lost when the file is moved to the **FAT Partition**



LNS.exe from (<http://ntsecurity.nu/cgi-bin/download/lns.exe.pl>) can detect streams



Luồng dữ liệu NTFS

NTFS Stream Detectors



ADS Spy

<http://www.merijn.nu>



LADS

<http://www.heysoft.de>



NTFS Streams Info

<http://www.isgeo.kiev.ua>



ADS Locator

<http://www.safer-networking.org>



List NTFS Streams (LNS)

<http://www.ntsecurity.nu>



StreamArmor

<http://www.rootkitanalytics.com>



Streams

<http://technet.microsoft.com>



ADS Manager

<http://dmitrybrant.com>

Steganography

What is **Steganography**?

- Steganography is a technique of **hiding a secret message** within an ordinary message and **extracting it at the destination** to maintain confidentiality of data
- **Utilizing a graphic image as a cover** is the most popular method to conceal the data in files



List of the
compromised
servers

Source code for
the hacking tool



Hiding
Messages

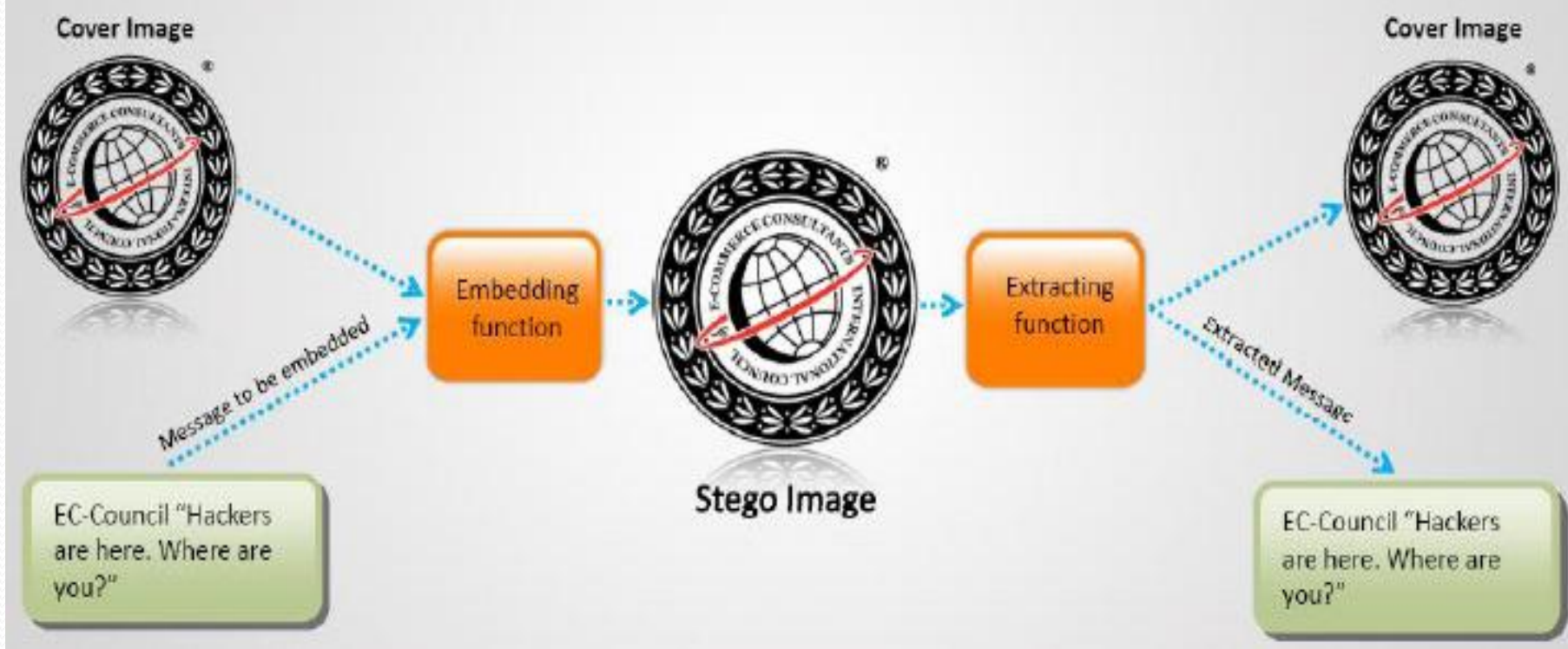
Plans for
future attacks

Communication
and coordination
channel



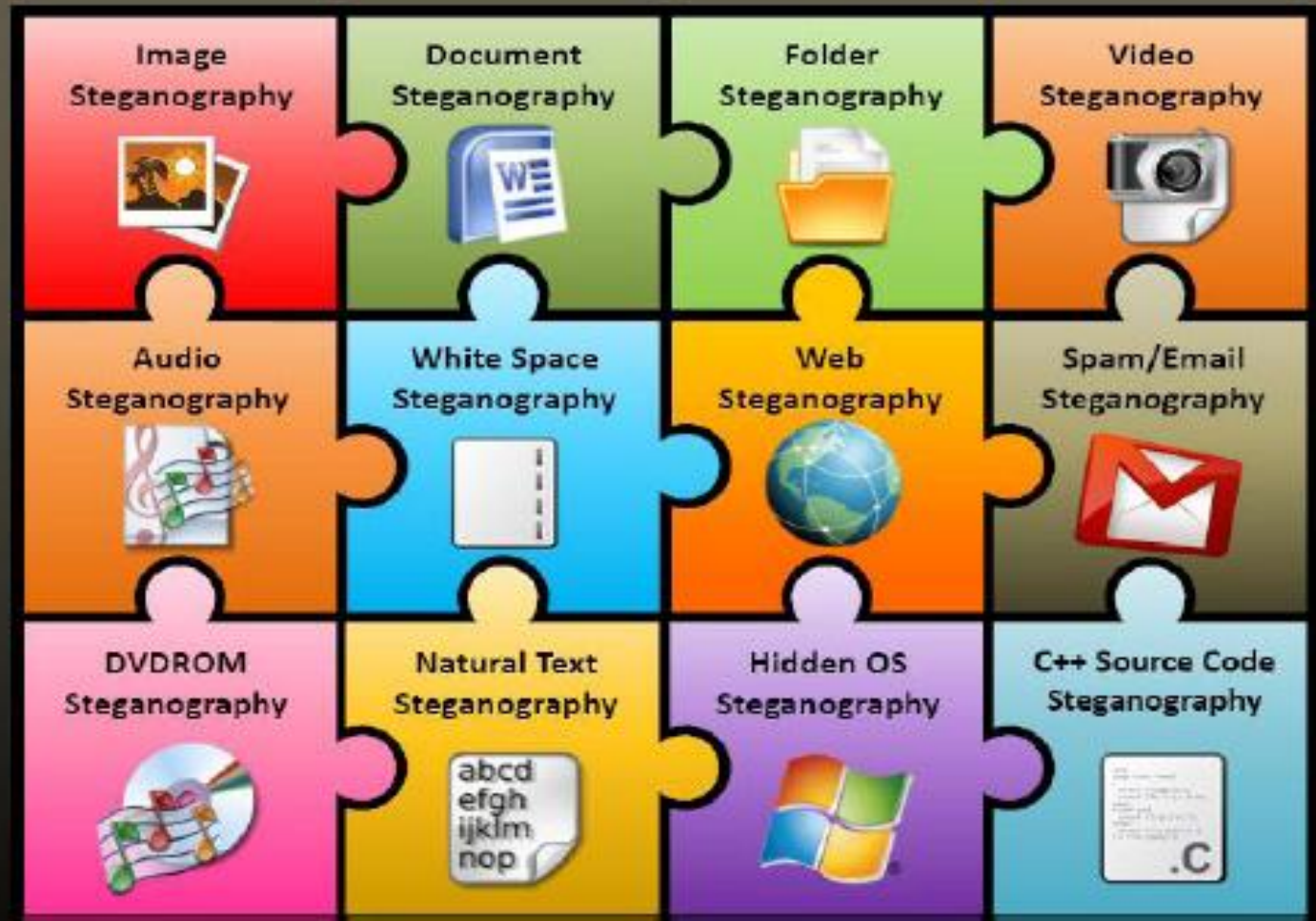
Steganography

How Steganography Works?



Steganography

Types of **Steganography**



Steganography

Image Steganography: **Hermetic Stego**

The screenshot shows the Hermetic Stego application window. The title bar reads 'Hermetic Stego'. The main interface has a yellow background. At the top, there are two radio buttons for 'Select operation:'. The first is selected: 'Encrypt the data file and hide it in the input image(s)'. The second is 'Extract the data file from the input image(s) and decrypt it'. Below this, there are two checkboxes: 'Select first input image' (unchecked) and 'Delete unsuitable input images (after confirmation)' (unchecked). There are three text input fields with 'Clear' buttons: 'File with data to be hidden' (C:\temp\input\finances.xls), 'Input images folder' (C:\temp\input\), and 'Stego images folder' (C:\temp\stego\). Each folder field has a 'List' button next to its 'Clear' button. Below these is a 'Select first input image file' button. On the left side, there are four buttons: 'View key', 'Hide the data', 'Save configuration', and 'Load configuration'. On the right side, there is a large text area displaying the operation details: 'Operation: Hide data', 'Data file: C:\temp\input\finances.xls', 'Data file size: 1,332,224 bytes', 'Input images folder: C:\temp\input\'', 'Stego images folder: C:\temp\stego\'', and 'The data was successfully hidden in the following 5 images: rock100.bmp (3,606,254 bytes) sf_cover.bmp (2,202,678 bytes)'. At the bottom, there are four buttons: 'Clear', 'Copy to clipboard', 'Help', and 'Quit'. The footer contains the copyright information 'Copyright 2003-2008 Hermetic Systems: www.hermetic.ch' and a link to the 'Online user manual'.

Hermetic Stego

Select operation: ☒ **Encrypt the data file and hide it in the input image(s)**
☐ Extract the data file from the input image(s) and decrypt it

☐ Select first input image ☐ Delete unsuitable input images (after confirmation)

File with data to be hidden: C:\temp\input\finances.xls [Clear]

Input images folder: C:\temp\input\ [Clear] [List]

Stego images folder: C:\temp\stego\ [Clear] [List]

Select first input image file

View key

Hide the data

Save configuration

Load configuration

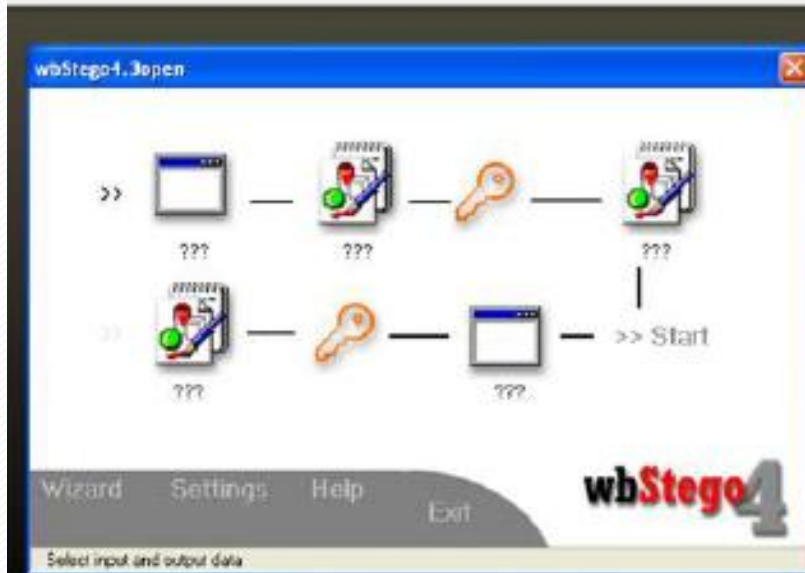
Operation: Hide data
Data file: C:\temp\input\finances.xls
Data file size: 1,332,224 bytes
Input images folder: C:\temp\input\
Stego images folder: C:\temp\stego\
The data was successfully hidden in the following 5 images:
rock100.bmp (3,606,254 bytes)
sf_cover.bmp (2,202,678 bytes)

[Clear] [Copy to clipboard] [Help] [Quit]

Copyright 2003-2008 Hermetic Systems: www.hermetic.ch Online user manual

Steganography

Document Steganography: **wbStego**



Steganography

Audio Steganography: Mp3stegz

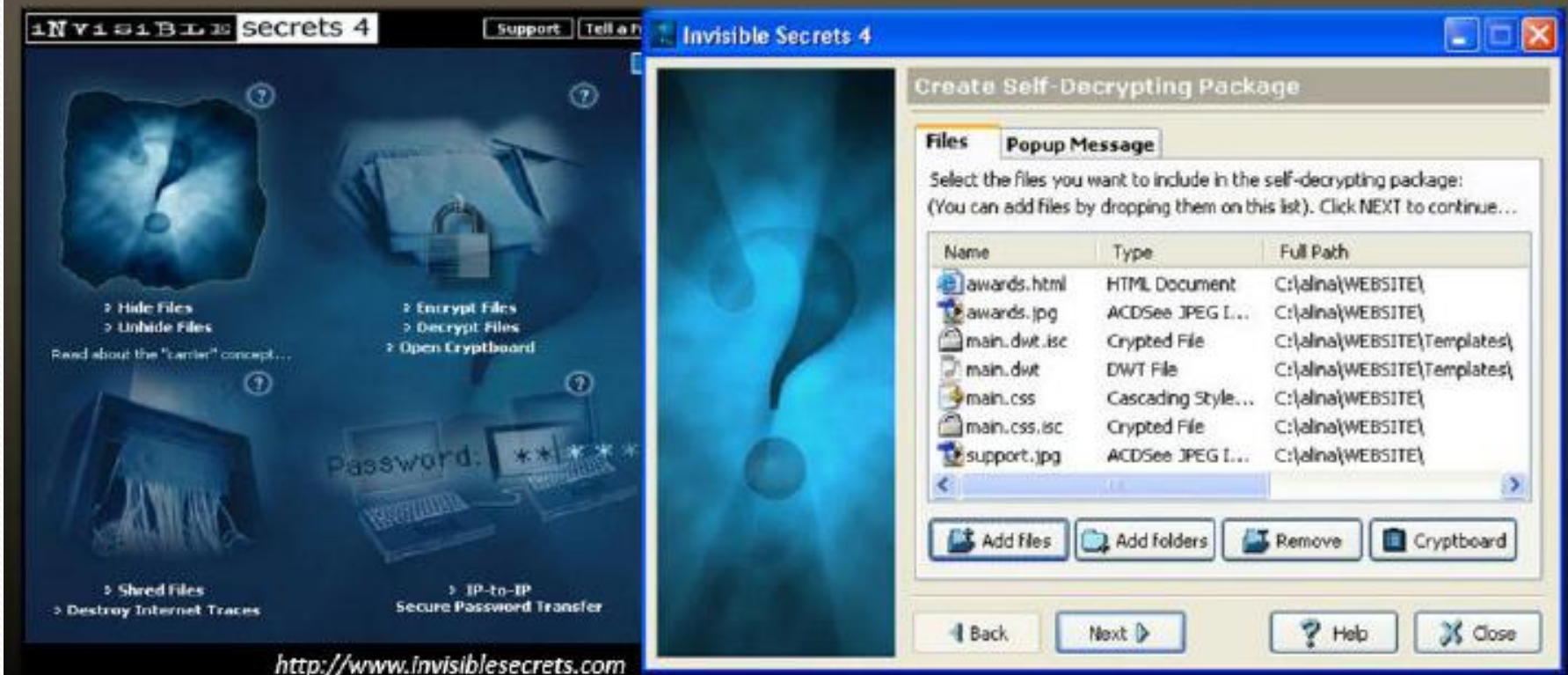
Audio steganography refers to hiding a secret information in **audio** files such as .MP3, .RM, .WAV, etc.



Steganography

Folder Steganography: **Invisible Secrets 4**

Folder steganography refers to hiding a secret information in **folders**



Steganography

Spam/Email Steganography: **Spam Mimic**

Spam steganography refers to hiding information in **spam messages**



Encode

Enter your short secret message:

Alternate encodings:

- Encode as spam with a password
- Encode as fake PGP
- Encode as fake Russian
- **new** Encode as space

[home](#) | [encode](#) | [decode](#) | [explanation](#) | [credits](#) | [faq & feedback](#)

Encoded

Your message **Hi, I am John** gets encoded into spam as:

Dear Friend , Especially for you - this breath-taking news ! If you no longer wish to receive our publications simply reply with a Subject: of "REMOVE" and you will immediately be removed from our database . This mail is being sent in compliance with Senate bill 1622 ; Title 4 , Section 302 . This is not a get rich scheme ! Why work for somebody else when you can become rich inside 68 days . Have you ever noticed most everyone has a cellphone and how many people you know are on the Internet . Well, now is your chance to capitalize on this . We will help you decrease perceived waiting time by 170% plus increase customer response by 170% ! You can begin at absolutely no cost to you . But don't believe us . Prof Jones of Washington tried us and says "My only problem now is where to park all my cars" ! This offer is 100% legal ! For the sake of your family order now ! Sign up a friend and you'll get a discount of 50% ! Thanks !

Steganography

Steganography **Detection** Tools



Xstegsecret

<http://stegsecret.sourceforge.net>



StegSpy

<http://www.spy-hunter.com>



Stego Watch

<http://www.wetstonetech.com>



**Gargoyle Investigator™
Forensic Pro**

<http://www.wetstonetech.com>



StegAlyzerAS

<http://www.sarc-wv.com>



StegAlyzerSS

<http://www.sarc-wv.com>



StegAlyzerRTS

<http://www.sarc-wv.com>



StegMark

<http://www.datamark.com.sg>

Xoá dấu vết



**Cracking
Passwords**



**Escalating
Privileges**



**Executing
Applications**



**Covering
Tracks**



**Hiding
Files**



**Penetration
Testing**

Xoá dấu vết

Why Cover Tracks?

Attackers cover tracks so that:

1. They can attack again
2. They can cover the tracks to avoid their detection
3. They can install backdoors to gain access in future



01:09 Action A1
01:09 Action A2
01:09 Action A3
01:09 Action A4
01:09 Action A5
01:09 Action A6

Manipulating the log files

1. **SECEVENT.EVT (security)**: Failed logins, accessing files without privileges
2. **SYSEVENT.EVT (system)**: Driver failure, things not operating correctly
3. **APPEVENT.EVT (applications)**

Altering event logs

The attacker might not want to delete the entire log



Xoá dấu vết

Covering Tracks

Once intruders have successfully **gained administrator access on a system**, they will try to cover the tracks to avoid their detection



Hacker



Gained administrator access



Target User

Install backdoors



When all the information of interest has been stripped off from the target, the intruder installs **several backdoors** so that he or she can gain easy access in the future

Xoá dấu vết

Disabling Auditing: **Auditpol**

- Intruders will **disable auditing** immediately after gaining administrator privileges
- At the end of their stay, the intruders will just turn on auditing again using auditpol.exe



```
D:\WINDOWS\system32\cmd.exe
D:\>auditpol.exe /enable
Running ...

Local audit information changed successfully ...
New local audit policy ...

<X> Audit Enabled

AuditCategorySystem           = No
AuditCategoryLogon            = No
AuditCategoryObjectAccess     = No
AuditCategoryPrivilegeUse     = No
AuditCategoryDetailedTracking = No
AuditCategoryPolicyChange     = No
AuditCategoryAccountManagemen = No
Unknown                       = No
Unknown                       = No

D:\>auditpol.exe /disable
Running ...

Local audit information changed successfully ...
New local audit policy ...

<Q> Audit Disabled

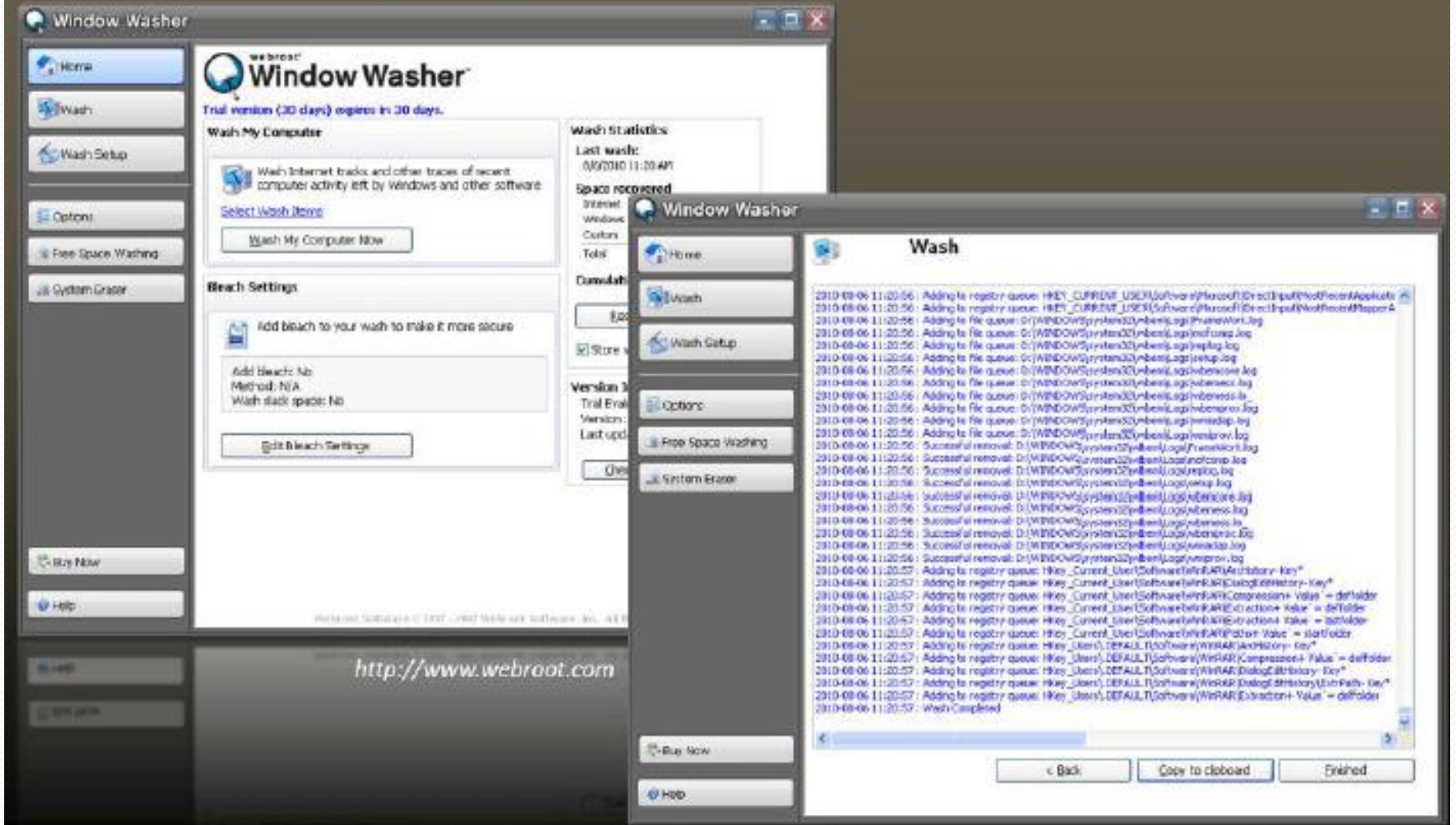
AuditCategorySystem           = No
AuditCategoryLogon            = No
AuditCategoryObjectAccess     = No
AuditCategoryPrivilegeUse     = No
AuditCategoryDetailedTracking = No
AuditCategoryPolicyChange     = No
AuditCategoryAccountManagemen = No
Unknown                       = No
Unknown                       = No

D:\>_
```

<http://www.microsoft.com>

Xoá dấu vết

Covering Tracks Tool: Window Washer



Xoá dấu vết

Covering Tracks Tool: Tracks Eraser Pro

The image displays two windows from the 'Covering Tracks Tool: Tracks Eraser Pro' software. The main window, titled 'Tracks Eraser Pro (Unregistered)', features a task list on the left and a sidebar with buttons on the right. The task list includes items like 'Firefox History', 'Firefox Saved Passwords', 'Windows Start Menu Recent Documents', 'Windows Find Files and Computers History', 'Windows Start Menu Run History', and 'Windows Temp Folder', all marked as 'Done'. The sidebar contains buttons for 'Erase Now', 'Test Now', 'Eraser Settings', 'Options', 'File Shredder', 'Log', 'About', 'Help', and 'Exit'. A status bar at the bottom indicates 'Test Scanned Registry Keys: 4 Files: 750 HD Space: 397.56 MB'. The 'Log Manager' window, titled 'Log Manager', shows a detailed log of operations performed, such as 'Test Mode: Erasing D:\Documents and Settings\...', 'Test Mode: Clearing Index File: D:\Documents and Settings\...', and 'Test Mode: Erasing Internet Cache Files: <OK>'. The log entries are organized in a table-like format with columns for the operation and the result.

Tracks Eraser Pro (Unregistered)

Task	Status
Firefox History	Done
Firefox Saved Passwords	Done
Windows Start Menu Recent Documents	Done
Windows Find Files and Computers History	Done
Windows Start Menu Run History	Done
Windows Temp Folder	Done

Test Mode: Test start.....at 8/6/2010 10:56:30 AM
Test Mode: Erasing IE Address Bar.....
Test Mode: Erasing IE Cookies.....
Test Mode: Erasing D:\Documents and Settings\.....
Test Mode: Erasing D:\Documents and Settings\.....
Test Mode: Erasing D:\Documents and Settings\.....
Test Scanned Registry Keys: 4 Files: 750 HD Space: 397.56 MB

Log Manager

Test Mode: Test Start.....at 8/6/2010 10:56:30 AM	
Test Mode: Erasing D:\Documents and Settings\.....	2doubleclick[1].txt <OK>
Test Mode: Erasing D:\Documents and Settings\.....	2lmsapplemobile[1].txt <OK>
Test Mode: Erasing D:\Documents and Settings\.....	2managengins[1].txt <OK>
Test Mode: Erasing D:\Documents and Settings\.....	2mcafee[1].txt <OK>
Test Mode: Erasing D:\Documents and Settings\.....	2office.microw[2].txt <OK>
Test Mode: Erasing D:\Documents and Settings\.....	2office14client.microw[2].txt <OK>
Test Mode: Erasing D:\Documents and Settings\.....	2softon[1].txt <OK>
Test Mode: Erasing D:\Documents and Settings\.....	2vao-telegraphy.en.softon[2].txt <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	1Cookies\index.dat <OK>
Test Mode: Erasing Internet Cache Files: <OK>	
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\Temporary Internet Files\content.ie5\index.dat <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\History\History.IE5\MS Hist012010071920100726\index.dat <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\History\History.IE5\MS Hist012010072620100802\index.dat <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\History\History.IE5\MS Hist012010072620100729\index.dat <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\History\History.IE5\MS Hist012010072920100730\index.dat <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\History\History.IE5\MS Hist012010080420100805\index.dat <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\History\History.IE5\MS Hist012010080520100806\index.dat <OK>
Test Mode: Clearing Index File: D:\Documents and Settings\.....	Local Settings\History\History.IE5\MS Hist012010080620100807\index.dat <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\5338523\desktop.ini <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\5338523\work[1] <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\53ACWDE\desktop.ini <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\53ACWDE\work[1] <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\53EYFQ\desktop.ini <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\53EYFQ\work[1] <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\53H4WZK\desktop.ini <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Feeds\Cache\53H4WZK\work[1] <OK>
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Internet Explorer\Recovery\Last Active\Recovery...
Test Mode: Erasing D:\Documents and Settings\.....	Local Settings\Application Data\Microsoft\Internet Explorer\Recovery\Last Active\Recovery...
Test Mode: Erasing AutoComplete Menus <OK>	

<http://www.acesoft.net>

Xoá dấu vết

Track Covering Tools



Evidence Eliminator

<http://www.evidence-eliminator.com>



Traceless

<http://www.nonags.com>



Armor Tools

<http://www.armortools.com>



WinZapper

<http://ntsecurity.nu>



Clear My History

<http://www.hide-my-ip.com>



ZeroTracks

<http://www.kleinsoft.co.za>



EvidenceEraser

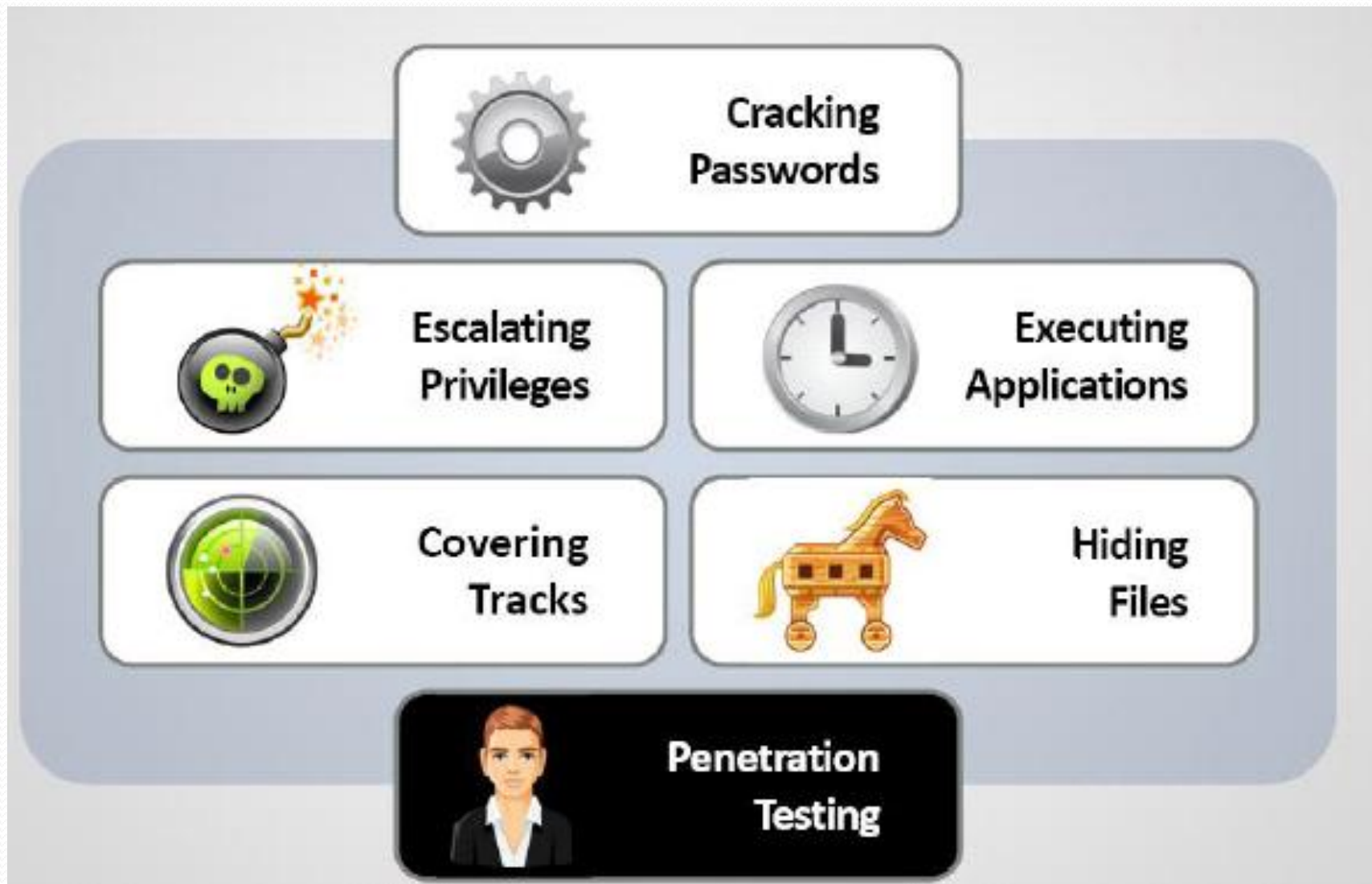
<http://www.evidenceeraser.com>



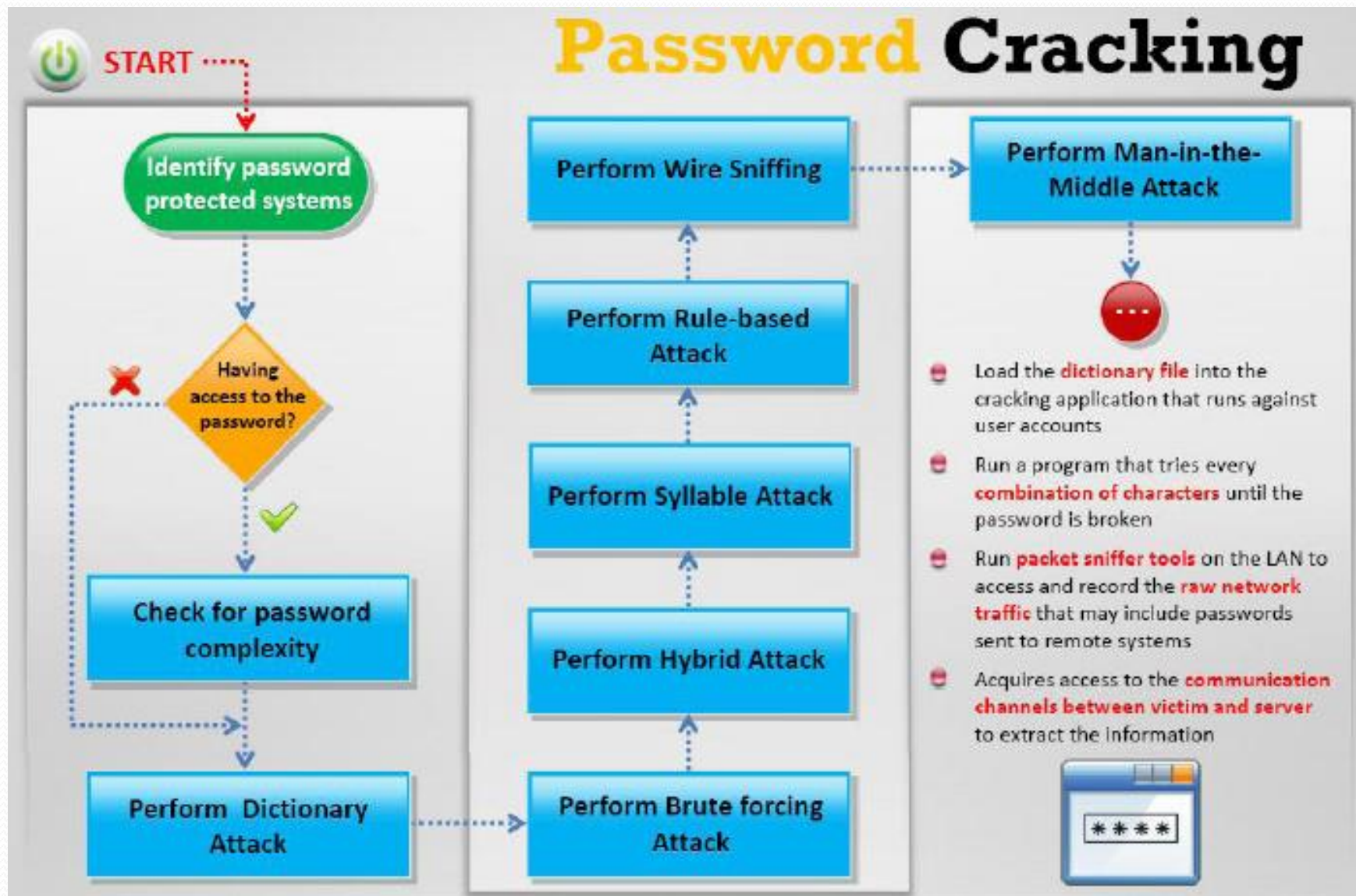
WinTools.net Ultimate

<http://www.wintools.net>

Kiểm thử



Kiểm thử



Kiểm thử

Password Cracking



Perform Replay
Attack

Perform Shoulder
Surfing

Perform Password
Guessing

Perform Social
Engineering

Perform
Trojan/Spyware/
keyloggers

Perform
Dumpster Diving

Perform Hash
Injection Attack

Perform Pre-
Computed Hashes

Perform Rainbow
Attack

Perform Distributed
Network Attack

- Use a **Sniffer** to capture packets and authentication tokens. After extracting relevant info, place back the tokens on the network to gain access
- Record every keystroke** that an user types using keyloggers
- Secretly **gather person or organization personal information** using spyware
- With the help of a **trojan** get access to the stored passwords in the Trojaned computer
- Inject a compromised hash** into a local session and use the hash to validate to network resources
- Recover password-protected files using the unused processing power of **machines across the network** to decrypt password



Kiểm thử

Privilege Escalation



START....

Try to login with
enumerated usernames
and cracked passwords

Interactive
logon
privileges are
restricted?



Try to replace
sethc.exe with cmd.exe

Try to create a hidden
admin account



Infect target with
keylogger to collect
domain passwords

Try to run services as
unprivileged accounts



Replace the **sethc.exe** which is responsible for the sticky key dialog, with **cmd.exe**, and then call **sethc.exe** by pressing shift key 5 times at logon screen to get the command prompt with administrator privileges



Use **privilege escalation tools** such as Active@ Password Changer, Passware Password Recovery Kit, Password Unlocker Bundle, ElcomSoft System Recovery, etc.



Kiểm thử

Executing Applications



START

Check if antivirus software is installed and up to date

Check if firewall software and anti-keylogging software are installed

Check if the hardware systems are secured in a locked environment

Try to use keyloggers

Try to use Spywares

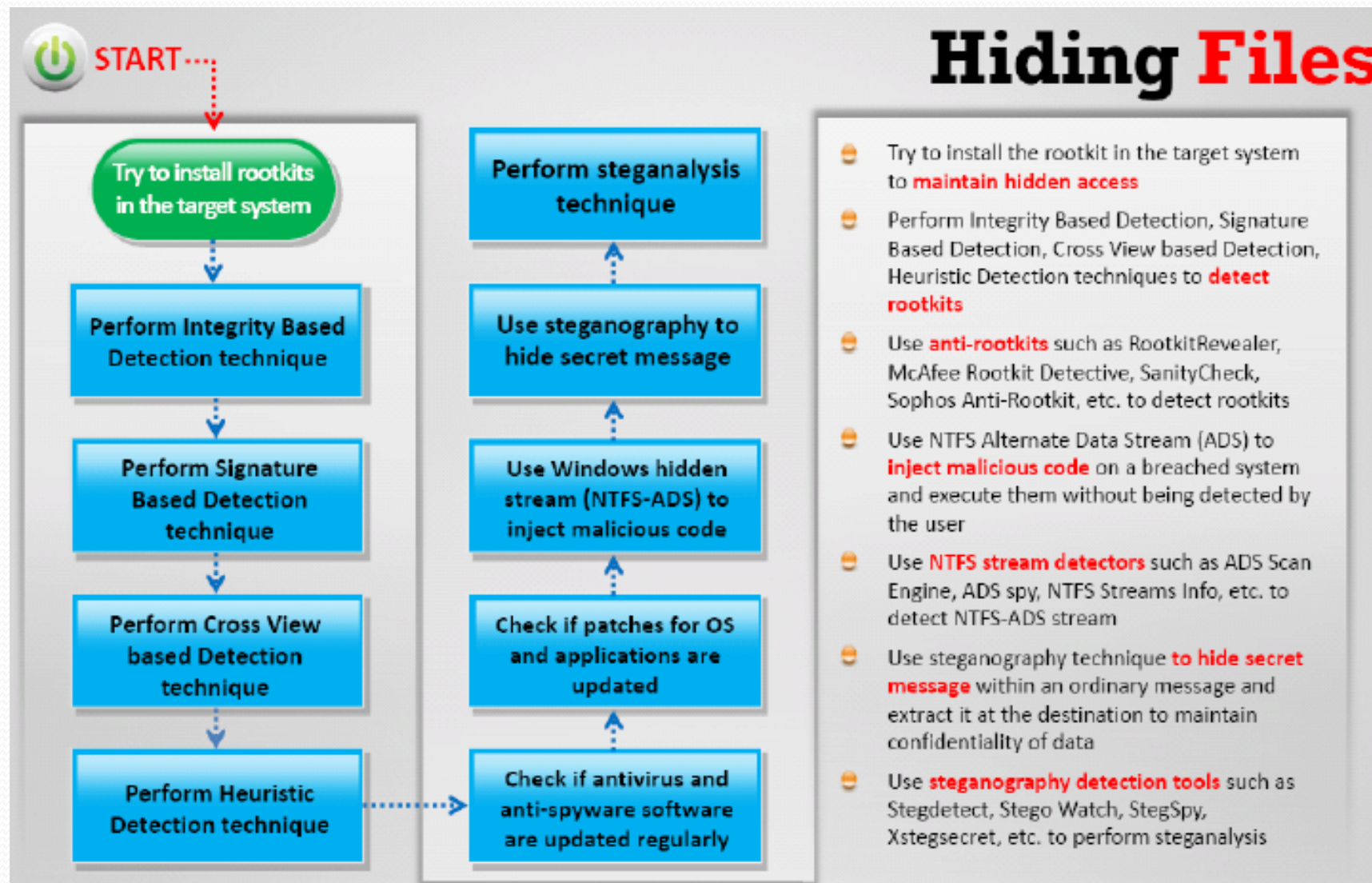
Use tools for remote execution



- Use **keyloggers** such as Advanced Keylogger, Spytech SpyAgent, Perfect Keylogger, Powered Keylogger, etc.
- Use **spywares** such as Robo Nanny, Stealth Recorder Pro, Net Video Spy, WebcamMagic, Mobile Spy, etc.

Kiểm thử

Hiding Files



Kiểm thử

Covering Tracks



BÀI TẬP

1. Lập bảng trình bày các kỹ thuật crack mật khẩu
2. Nêu các biện pháp bảo vệ mật khẩu
3. Phân loại spyware và nêu biện pháp phòng chống
4. Steganography là gì? Lập bảng trình bày các phương thức Steganography.
5. NTFS data stream là gì? Cho ví dụ về cách tạo file sử dụng NTFS data stream.